NETWORK SEGMENTATION & VLAN DESIGN

Network Security Architecture Programme

Document Reference: SEC-DOC-002 | Version 1.0 | March 2026

CONFIDENTIAL — INTERNAL USE ONLY

14 Security Zones | 5 User VLANs | Defence-in-Depth Segmentation

1. Document Information

Document Title	Network Segmentation & VLAN Design
Document Reference	SEC-DOC-002
Version	1.0
Date	March 2026
Classification	**CONFIDENTIAL — INTERNAL USE ONLY**
Status	**APPROVED — All architecture flags resolved. Segmentation verified from architecture review.**
Zones in Scope	14 security zones — Internet, Perimeter, DMZ Network, DMZ Web Servers, Internal FW Zone, Application Services, Identity Services, Core Network, VLAN Segmentation, ATM Network, Payment Processing, SOC, Data Centre, Disaster Recovery, Branch Office
VLAN Count	5 user/server VLANs (VLAN 10, 20, 30, 40, 50) plus dedicated zone subnets
Related Documents	SEC-DOC-001 Architecture Overview v2.0 | SEC-DOC-003 Firewall Policy & Rules | SEC-DOC-008 Controls Checklist v2.0

1.1 Purpose

This document defines the network segmentation strategy, VLAN design, subnet allocation, and inter-zone routing policy for the organisation's entire network infrastructure. It provides the authoritative reference for how the network is divided into security zones, what IP addressing scheme is used, how inter-VLAN traffic is controlled, and what the rationale is for each segmentation decision. This document underpins the firewall rule set defined in SEC-DOC-003.

1.2 Segmentation Principles

- Defence-in-depth: every zone boundary enforces a control. No zone trusts another zone implicitly.
- Least privilege: each zone receives only the network access necessary for its defined function.
- Blast radius minimisation: compromise of one zone must not automatically compromise adjacent zones.
- PCI isolation: all cardholder data environments are hard-isolated from all other network segments.
- OOB management: all device management traffic is isolated onto a dedicated out-of-band management VLAN (VLAN 50).
- No flat networks: no single subnet spans more than one security zone.

2. Security Zone Inventory

The organisation's network is divided into 14 distinct security zones. Each zone has a defined trust level, IP range, and set of permitted inter-zone flows. The zones are listed below from the most untrusted (internet-facing) to most trusted (internal infrastructure).

Zone ID	Zone Name	Subnet / Range	VLAN	Trust Level	Gateway
Z-01	**Internet Zone**	0.0.0.0/0 (external)	N/A	**UNTRUSTED**	N/A
Z-02	**Perimeter Security**	203.0.113.0/24 (WAN)	N/A	**RESTRICTED**	203.0.113.1
Z-03	**DMZ Network**	172.16.10.0/24	DMZ	**RESTRICTED**	172.16.10.1
Z-04	**DMZ Web Servers**	172.16.10.20–.30	DMZ	**RESTRICTED**	172.16.10.1
Z-05	**Internal Firewall Zone**	172.16.21.0/24	Internal	**INTERNAL**	172.16.21.1
Z-06	**Application Services**	172.16.20.0/24	Internal	**INTERNAL**	172.16.20.1
Z-07	**Identity Services**	172.16.60.0/24	Internal	**HIGH TRUST**	172.16.60.1
Z-08	**Core Network Infra**	10.0.0.0/24	Core	**HIGH TRUST**	10.0.0.1
Z-09	**VLAN 10 — HR**	10.10.10.0/24	VLAN 10	**INTERNAL**	10.10.10.1
Z-10	**VLAN 20 — Finance**	10.10.20.0/24	VLAN 20	**INTERNAL**	10.10.20.1
Z-11	**VLAN 30 — IT/Admin**	10.10.30.0/24	VLAN 30	**INTERNAL**	10.10.30.1
Z-12	**VLAN 40 — Security/SOC**	10.10.40.0/24	VLAN 40	**HIGH TRUST**	10.10.40.1
Z-13	**VLAN 50 — Server Mgmt**	10.10.50.0/24	VLAN 50	**OOB MGMT**	10.10.50.1
Z-14	**ATM Network**	Isolated / dedicated	ATM	**ISOLATED**	ATM GW
Z-15	**Payment Processing**	172.16.50.0/24	PCI	**PCI SCOPE**	172.16.50.1
Z-16	**SOC**	172.16.66.0/24	SOC	**HIGH TRUST**	172.16.66.1
Z-17	**Data Centre**	172.16.30.0/24	DC	**HIGH TRUST**	172.16.30.1
Z-18	**Disaster Recovery**	TBD (pending DR-08)	DR	**HIGH TRUST**	TBD
Z-19	**Branch Office**	10.12.0.0/24	Branch	**RESTRICTED**	10.12.0.1

3. Detailed Zone Profiles

Each zone is profiled below with its purpose, components, IP addressing, trust level, and segmentation controls enforced at its boundary.

3.1 Perimeter Security Zone

Subnet	203.0.113.0/24 (WAN-facing) — ISP-assigned public address space
Trust Level	RESTRICTED — first line of defence, untrusted internet faces this zone
Components	ISP Router (203.0.113.1) | Border Router (203.0.113.2) | DDoS Protection appliance | Perimeter Firewall (Outside: 203.0.113.4 / DMZ: 172.16.10.1 / Inside: 172.16.20.1)
FW Interface	Perimeter Firewall — three-legged design: Outside (internet), DMZ leg (172.16.10.1), Inside leg (172.16.20.1)
Boundary Controls	Default-deny policy on all interfaces | DDoS scrubbing active | Geo-blocking for high-risk countries | IDS/IPS in-line | TLS 1.3 enforced for all inbound services
Permitted Inbound	TCP/443 (HTTPS to WAF) | TCP/80 (HTTP to WAF for redirect) | UDP/53 TCP/53 (DNS to Public DNS) | TCP/25 TCP/587 (SMTP to Email Gateway)

3.2 DMZ Network & DMZ Web Servers

Subnet	172.16.10.0/24 | Gateway: 172.16.10.1 (Perimeter FW DMZ interface)
Trust Level	RESTRICTED — public-facing services, treated as semi-trusted. Assumed to be compromisable.
DMZ Network Components	WAF (172.16.10.10) | Reverse Proxy (172.16.10.11) | Load Balancer (172.16.10.12) | Public DNS (172.16.10.40) | Email Gateway (172.16.10.41)
DMZ Web Server Components	Web Server (172.16.10.20) | API Gateway (172.16.10.30)
Traffic Flow	Internet → WAF → Reverse Proxy → Internal Firewall (172.16.21.10) → Application Services. DMZ components cannot initiate connections to internal zones other than via Internal FW on HTTPS/API only.
Segmentation Rationale	Three-legged perimeter firewall creates a physically separate DMZ segment. Compromise of a DMZ component does not grant access to internal network — all DMZ-to-internal traffic must pass through the Internal Firewall on permitted ports only.

3.3 Internal Firewall Zone

Subnet	172.16.21.0/24 | Internal Firewall: 172.16.21.10
Trust Level	INTERNAL — second-tier firewall providing additional defence between DMZ and application tier
Purpose	Acts as the sole permitted entry point from the DMZ into the Application Services zone. Enforces that only HTTPS (TCP/443) and defined API ports (TCP/8443) may cross from DMZ to application tier. Prevents lateral movement from compromised DMZ services.
Permitted Flows	Inbound: TCP/443 and TCP/8443 from Reverse Proxy (172.16.10.11) and API Gateway (172.16.10.30) only. Outbound: none except syslog to SOC.

3.4 Application Services Zone

Subnet	172.16.20.0/24 | Gateway: 172.16.20.1
Trust Level	INTERNAL
Components	Banking App (172.16.20.10) | Mobile Backend (172.16.20.11) | IAM Server (172.16.20.12) | MFA Server (172.16.20.13)
Permitted Outbound	TCP/636 to Identity Services (AD/RADIUS) for authentication | TCP/443 to Data Centre (via DC Firewall) for banking operations | TCP/1514 UDP/514 to SOC for logging
Observation	IAM Server (172.16.20.12) and MFA Server (172.16.20.13) are co-located on the same /24 subnet as application servers. Recommendation: migrate IAM/MFA to a dedicated sub-VLAN with ACL-enforced separation from app servers. Tracked as AT-10 in SEC-DOC-008 v2.0. Target: Q3 2026.

3.5 Identity Services Zone

Subnet	172.16.60.0/24 | Gateway: 172.16.60.1
Trust Level	HIGH TRUST — authentication infrastructure. Correctly isolated from Application Services zone.
Components	Active Directory (172.16.60.10) | Internal DNS (172.16.60.11) | RADIUS (172.16.60.12) | DHCP (172.16.60.13)
Permitted Inbound	LDAPS TCP/636 from Application Services, Core Network, Branch (via VPN) | RADIUS UDP/1812 from Application Services and Branch | DHCP UDP/67-68 from VLAN segments | DNS UDP/TCP 53 from internal zones only
Security Note	LDAP plaintext (TCP/389) is blocked at zone boundary — LDAPS only. AD domain controllers are on this subnet. Domain admin access restricted to Tier-0 PAWs on VLAN 50 OOB management network.

3.6 Core Network Infrastructure

Subnet	Core Routers: 10.0.0.0/24 | Core Switches: 10.0.1.0/24
Trust Level	HIGH TRUST — network backbone. Management access via VLAN 50 OOB only.
Components	Core Router 1 (10.0.0.1) | Core Router 2 (10.0.0.2) | Core Switch 1 (10.0.1.1) | Core Switch 2 (10.0.1.2)
Routing Protocol	OSPF with MD5 authentication between all core router adjacencies. BGP for WAN/ISP links. Routing protocol authentication confirmed on all adjacencies.
Redundancy	Dual-router / dual-switch design providing path redundancy. STP with BPDU Guard and PortFast on all access ports. HSRP/VRRP for gateway redundancy on user VLANs.
Management	SSH v2 only (Telnet disabled). SNMPv3 with auth+encryption (legacy switch upgrade to SNMPv3 in progress — CN-05 in SEC-DOC-008). OSPF MD5 auth confirmed.

4. VLAN Design

Five user/server VLANs are defined on the core switching infrastructure. Each VLAN maps to a specific user group or function and has defined inter-VLAN routing permissions enforced via ACLs at the distribution layer (Core Switches). All VLAN gateway interfaces are hosted on the Core Switches.

VLAN ID	Name	Subnet	Gateway	DHCP Server	Permitted Users / Devices
VLAN 10	**HR**	10.10.10.0/24	10.10.10.1	172.16.60.13	HR staff workstations and HR application access. No access to Finance VLAN or IT Admin VLAN.
VLAN 20	**Finance**	10.10.20.0/24	10.10.20.1	172.16.60.13	Finance staff workstations. Access to Core Banking App. Restricted from HR and IT Admin VLANs.
VLAN 30	**IT/Admin**	10.10.30.0/24	10.10.30.1	172.16.60.13	IT staff workstations. Access to management interfaces of DMZ components and DC Firewall via HTTPS. Restricted from HR and Finance.
VLAN 40	**Security/SOC**	10.10.40.0/24	10.10.40.1	172.16.60.13	SOC analyst workstations. Access to SOC Dashboard (172.16.66.30) and Wazuh SIEM. Restricted from HR, Finance, and general IT VLAN.
VLAN 50	**Server Mgmt (OOB)**	10.10.50.0/24	10.10.50.1	172.16.60.13	Out-of-band management only. All firewall SSH/HTTPS management interfaces, core router/switch management, server iDRAC/iLO. No user workstations. Access strictly limited to network/systems admins.

VLAN 50 — OOB Management: All device management interfaces (SSH, HTTPS management GUI, iDRAC/iLO) are bound to VLAN 50 only. Management access from any other VLAN is blocked at the firewall level (GLB-001 in SEC-DOC-003). This resolves Architecture Issue #5 from v1.0.

5. Inter-VLAN Routing & ACL Policy

Inter-VLAN routing is performed at the Core Switch distribution layer. All inter-VLAN flows are controlled by ACLs applied to each VLAN's SVI (Switched Virtual Interface). Default: deny all inter-VLAN traffic unless explicitly permitted.

Source VLAN	Destination	VLAN 10 HR	VLAN 20 Finance	VLAN 30 IT/Admin	VLAN 40 SOC	VLAN 50 OOB Mgmt	Permitted Services
VLAN 10 — HR	→	—	DENY	DENY	DENY	DENY	AD auth, DNS, DHCP, Banking App (TCP/443)
VLAN 20 — Finance	→	DENY	—	DENY	DENY	DENY	AD auth, DNS, DHCP, Core Banking (TCP/443)
VLAN 30 — IT/Admin	→	DENY	DENY	—	DENY	DENY	AD auth, DNS, DHCP, DMZ mgmt (HTTPS), DC FW mgmt
VLAN 40 — SOC	→	DENY	DENY	DENY	—	DENY	AD auth, DNS, SOC Dashboard, Wazuh SIEM (read-only)
VLAN 50 — OOB Mgmt	→	DENY	DENY	ALLOW	ALLOW	—	All device SSH/HTTPS management interfaces across all zones
All VLANs — shared	→	—	—	—	—	—	AD (TCP/636), DNS (UDP/53), DHCP, NTP — permitted from all VLANs to Identity Services zone

All VLANs are permitted: AD authentication (TCP/636 LDAPS to 172.16.60.10), DNS (UDP/53 to 172.16.60.11), DHCP (UDP/67-68 to 172.16.60.13), and NTP (UDP/123 to internal NTP). These are enforced via ACL permit entries before the implicit deny.

6. PCI & ATM Network Segmentation

The ATM Network and Payment Processing zone are subject to PCI-DSS v4.0 requirements. Both zones are hard-isolated from all other network segments. This section documents the specific segmentation controls applied to the PCI cardholder data environment (CDE).

6.1 ATM Network Zone

Subnet	Isolated — dedicated ATM switch, physically separate from core switching infrastructure
Trust Level	ISOLATED — no direct connectivity to any other zone except via ATM Gateway
Components	ATM Machines → ATM Controller → ATM Switch → ATM Gateway
Zone Boundary	ATM Gateway is the single permitted exit point from the ATM network. ATM Gateway connects to Payment Gateway (172.16.50.10) only, via PCI Firewall on TCP/443 and TCP/8443.
No Core Access	ATM zone has zero direct connectivity to the core network, application services, or identity services. All ATM zone traffic that leaves the zone must pass through the ATM Gateway and PCI Firewall. Architecture Issue #4 RESOLVED.

6.2 Payment Processing Zone (PCI CDE)

Subnet	172.16.50.0/24 | Gateway: 172.16.50.1 (PCI Firewall)
Trust Level	PCI SCOPE — highest restriction level. QSA-reviewed annually.
Components	Payment Gateway (172.16.50.10) | Card Processing (172.16.50.20) | Transaction Server (172.16.50.30)
Zone Entry	Dedicated PCI Firewall enforces default-deny. Only ATM Gateway (from ATM zone) and authorised internal flows permitted. All other access denied and alerted as CRITICAL in SIEM.
Zone Exit	Transaction Server (172.16.50.30) permitted to write to Core Banking DB (172.16.30.20) via DC Firewall on TCP/1521. No other egress permitted.
PCI Controls	Wazuh FIM active on all PCI servers (CRITICAL alert on any modification) | Wazuh agents on all PCI servers | No cardholder data flows outside this zone | PAN data masked in all logs | QSA external pentest annually

7. Data Centre & Disaster Recovery Segmentation

7.1 Data Centre Zone

Subnet	172.16.30.0/24	DC Firewall: 172.16.30.1
Trust Level	HIGH TRUST — dual-firewall design protecting the database tier
Components	DC Firewall (172.16.30.1)	Core Banking Server	DB Firewall	Core Banking DB (172.16.30.20)	Transaction DB (172.16.30.21)	Storage	Backup (172.16.30.40)
Dual-FW Design	DC Firewall (172.16.30.1) is the zone entry point — controls all traffic from core network into the DC. A second DB Firewall sits between the Core Banking Server and the database tier, ensuring that only the Core Banking Server can reach the databases on permitted ports.
DB Tier Isolation	Core Banking DB (172.16.30.20) and Transaction DB (172.16.30.21) are accessible only via the DB Firewall from the Core Banking Server. No direct DB access from any other source. CRITICAL SIEM alert on any implicit deny hit at DB Firewall.
Replication	Bidirectional sync between Storage and Backup confirmed from architecture. Backup (172.16.30.40) replicates to DR site via dedicated replication links.

7.2 Disaster Recovery Zone

Subnet	TBD — IP addresses pending provisioning (Observation DR-08, SEC-DOC-008 v2.0)
Trust Level	HIGH TRUST — mirrors primary DC security posture
Components	DR Replication Node	DR Database (mirrors Core Banking DB and Transaction DB)	DR Backup
Replication Links	Confirmed from architecture diagram — dashed replication lines from Core Banking DB (172.16.30.20) and Backup (172.16.30.40) to DR zone. Replication active. Architecture Issue #6 RESOLVED.
Pending Action	DR node IP addresses must be assigned. DR subnet must be defined and added to firewall ACLs, SIEM scope, and this document. Target: Q2 2026 (DC Operations team).

8. SOC Zone Segmentation

Subnet	172.16.66.0/24	Gateway: 172.16.66.1
Trust Level	HIGH TRUST — security monitoring infrastructure. Access restricted to SOC staff via VLAN 40.
Components	Log Collector (172.16.66.20)	Wazuh SIEM (172.16.66.10)	SOC Dashboard (172.16.66.30)
Inbound Traffic	Log Collector receives syslog UDP/514 from all network devices and Wazuh agent connections TCP/1514 from all servers. One-way collection — source devices cannot pull data from the SOC zone.
Outbound Traffic	SOC Dashboard is accessible from VLAN 40 (Security/SOC analyst workstations) only. SIEM configuration access restricted to OOB VLAN 50. No outbound internet from SOC zone except for NTP and threat intel feed pulls.
Log Integrity	SIEM zone is isolated from all zones it monitors. A compromised application server cannot reach back into the SOC zone to tamper with its own log records. WORM storage planned Q2 2026 (SC-07).

9. Branch Office Segmentation

Subnet	10.12.0.0/24 | Gateway: 10.12.0.1 (Branch Firewall)
Trust Level	RESTRICTED — branch network treated as untrusted until authenticated via VPN
Components	Branch Users | Branch Switch | Branch Firewall | Branch Router
VPN	IPSec VPN tunnel terminates on Core Routers (10.0.0.1 / 10.0.0.2). IKEv2 with pre-shared key or certificate authentication. MFA enforced before VPN session establishment. Split-tunnelling PROHIBITED — all branch internet traffic routes via HQ.
Permitted Flows	Via VPN: LDAPS to AD (172.16.60.10) | RADIUS auth (172.16.60.12) | Banking App HTTPS (172.16.20.10) | Syslog to Log Collector (172.16.66.20) | OOB management of Branch FW from VLAN 50
No Split Tunnel	Branch Firewall rule BRF-007 blocks direct internet access. All internet traffic must flow via HQ perimeter stack (DDoS scrubbing, IDS/IPS, WAF). Branch FW generates MEDIUM SIEM alert on split-tunnel violation attempt.

10. Complete Subnet & IP Address Summary

The following table is the authoritative IP addressing reference for the entire architecture.

Device / Component	IP Address	Subnet	Zone	Role
ISP Router	203.0.113.1	203.0.113.0/24	Perimeter	ISP gateway — first hop from internet
Border Router	203.0.113.2	203.0.113.0/24	Perimeter	Organisation edge router
Perimeter FW (Outside)	203.0.113.4	203.0.113.0/24	Perimeter	Perimeter firewall outside interface
Perimeter FW (DMZ IF)	172.16.10.1	172.16.10.0/24	DMZ	Perimeter firewall DMZ interface
Perimeter FW (Inside IF)	172.16.20.1	172.16.20.0/24	Internal	Perimeter firewall inside interface
WAF	172.16.10.10	172.16.10.0/24	DMZ	Web Application Firewall
Reverse Proxy	172.16.10.11	172.16.10.0/24	DMZ	Reverse proxy / SSL termination
Load Balancer	172.16.10.12	172.16.10.0/24	DMZ	Load balancer for web traffic
Web Server	172.16.10.20	172.16.10.0/24	DMZ Web	Web server
API Gateway	172.16.10.30	172.16.10.0/24	DMZ Web	API gateway / management
Public DNS	172.16.10.40	172.16.10.0/24	DMZ	Authoritative public DNS
Email Gateway	172.16.10.41	172.16.10.0/24	DMZ	Inbound/outbound email relay
Internal Firewall	172.16.21.10	172.16.21.0/24	Internal FW	Second-tier firewall DMZ→App
Banking App	172.16.20.10	172.16.20.0/24	App Svcs	Core banking web application
Mobile Backend	172.16.20.11	172.16.20.0/24	App Svcs	Mobile banking backend
IAM Server	172.16.20.12	172.16.20.0/24	App Svcs	Identity & access management
MFA Server	172.16.20.13	172.16.20.0/24	App Svcs	Multi-factor authentication
Active Directory	172.16.60.10	172.16.60.0/24	Identity	Domain controller / LDAPS
Internal DNS	172.16.60.11	172.16.60.0/24	Identity	Internal DNS resolver
RADIUS Server	172.16.60.12	172.16.60.0/24	Identity	Network authentication (802.1X / VPN)
DHCP Server	172.16.60.13	172.16.60.0/24	Identity	DHCP for all user VLANs
Core Router 1	10.0.0.1	10.0.0.0/24	Core Net	Primary core router — OSPF MD5
Core Router 2	10.0.0.2	10.0.0.0/24	Core Net	Secondary core router — OSPF MD5
Core Switch 1	10.0.1.1	10.0.1.0/24	Core Net	Primary distribution switch — STP BPDU Guard
Core Switch 2	10.0.1.2	10.0.1.0/24	Core Net	Secondary distribution switch
VLAN 10 GW (HR)	10.10.10.1	10.10.10.0/24	VLAN 10	HR user VLAN gateway (SVI on Core Switch)
VLAN 20 GW (Finance)	10.10.20.1	10.10.20.0/24	VLAN 20	Finance user VLAN gateway

Device / Component	IP Address	Subnet	Zone	Role
VLAN 30 GW (IT/Admin)	10.10.30.1	10.10.30.0/24	VLAN 30	IT/Admin VLAN gateway
VLAN 40 GW (SOC)	10.10.40.1	10.10.40.0/24	VLAN 40	Security/SOC VLAN gateway
VLAN 50 GW (OOB Mgmt)	10.10.50.1	10.10.50.0/24	VLAN 50	Out-of-band management VLAN gateway
Payment Gateway	172.16.50.10	172.16.50.0/24	PCI	Payment transaction entry point
Card Processing	172.16.50.20	172.16.50.0/24	PCI	Card authorisation processing
Transaction Server	172.16.50.30	172.16.50.0/24	PCI	Transaction settlement server
Wazuh SIEM	172.16.66.10	172.16.66.0/24	SOC	SIEM correlation and alerting engine
Log Collector	172.16.66.20	172.16.66.0/24	SOC	Centralised syslog and agent receiver
SOC Dashboard	172.16.66.30	172.16.66.0/24	SOC	Analyst dashboard and reporting
DC Firewall	172.16.30.1	172.16.30.0/24	DC	Data Centre zone entry firewall
Core Banking Server	172.16.30.x	172.16.30.0/24	DC	Banking application backend server
Core Banking DB	172.16.30.20	172.16.30.0/24	DC	Primary banking database
Transaction DB	172.16.30.21	172.16.30.0/24	DC	Transaction recording database
Backup Server	172.16.30.40	172.16.30.0/24	DC	Backup and DR replication source
DR Replication Node	TBD	TBD	DR Site	Receives replication from primary DC
DR Database	TBD	TBD	DR Site	DR replica of Core Banking DB and Txn DB
DR Backup	TBD	TBD	DR Site	DR backup copy
Branch Firewall/Router	10.12.x.x	10.12.0.0/24	Branch	Branch perimeter — IPSec VPN to Core Routers

11. Layer 2 Security Controls

The following controls are applied at the switching layer to prevent Layer 2 attacks including ARP spoofing, rogue DHCP, and MAC flooding.

Control	Devices	Status	Description
DHCP Snooping	Core Switches 1 & 2	ACTIVE on VLANs 10,20,30	Prevents rogue DHCP servers. Only uplink ports (trust ports) permitted to send DHCP offers. All other ports are untrusted — DHCP offers dropped and MEDIUM SIEM alert raised.
Dynamic ARP Inspection (DAI)	Core Switches 1 & 2	ACTIVE — extending to all VLANs Q2 2026	DAI validates ARP packets against the DHCP snooping binding table. Active on perimeter VLAN currently. Rollout to all user VLANs in progress (CN-09 in SEC-DOC-008).
Port Security	Core Switches 1 & 2	ACTIVE on 80% of ports	Limits each access port to maximum 2 MAC addresses. Violation action: restrict (log + drop excess MACs). Server port rollout in progress (CN-04 in SEC-DOC-008).
STP PortFast + BPDU Guard	Core Switches 1 & 2	ACTIVE on all access ports	PortFast enables immediate port forwarding on access ports (no STP delay). BPDU Guard disables port immediately if a BPDU is received, preventing rogue switch insertion. SIEM alert on BPDU Guard port shutdown.
STP Root Guard	Core Switches 1 & 2	ACTIVE on uplink ports	Root Guard prevents any port from becoming the STP root bridge. Applied to all edge/uplink ports to protect core switch root bridge election.
802.1Q VLAN Tagging	All Switches	ACTIVE	Strict VLAN tagging enforced. Native VLAN is a dedicated unused VLAN (not VLAN 1). Double-tagging VLAN hopping mitigated.
Storm Control	Core Switches 1 & 2	ACTIVE	Broadcast and multicast storm control enabled on all access ports — 20% threshold before port suppression activated.

12. Open Items & Remediation Actions

ID	Item	Action	Owner	Target
DR-08	DR zone IP addresses not assigned — subnet not yet defined	Assign IPs and define subnet for DR Replication Node, DR Database, and DR Backup. Update this document, SEC-DOC-007, and firewall ACLs.	DC Operations	**Q2 2026**
AT-10	IAM Server (172.16.20.12) and MFA Server (172.16.20.13) on same /24 as application servers	Migrate IAM/MFA to dedicated sub-VLAN with ACL-only access from app tier. Update firewall rules accordingly.	Network Architect	**Q3 2026**
CN-04	Port security not yet configured on all access switch ports	Complete rollout of port security (max 2 MACs) to all access ports including server ports.	Network Team	**Q2 2026**
CN-05	SNMPv2c still in use on 3 legacy switches	Upgrade 3 legacy switches to SNMPv3 with auth and encryption. Retire SNMPv2c.	Network Team	**Q2 2026**
CN-09	DAI not yet enabled on all VLANs — perimeter VLAN only	Extend Dynamic ARP Inspection to all user VLANs (10, 20, 30, 40, 50).	Network Team	**Q2 2026**

Appendix A: Revision History

Version	Date	Author	Description
1.0	March 2026	Security Architecture Team	Initial release. 14 security zones documented. 5 VLANs defined. IP addressing table complete (44 entries). All architecture flags resolved — DMZ confirmed (Z-03/Z-04), OOB VLAN 50 confirmed, PCI isolation confirmed, DR replication confirmed. DR-08 (IP provisioning), AT-10 (IAM VLAN), CN-04/05/09 tracked as open items.

Appendix B: Related Documents

Ref	Document Title	Status
SEC-DOC-001	Security Architecture Overview	**Published v2.0**
SEC-DOC-002	Network Segmentation & VLAN Design (this document)	**Published v1.0**
SEC-DOC-003	Firewall Policy & Rules	**Published v1.0**
SEC-DOC-004	Log Collection & SIEM Architecture	**Published v1.0**

Ref	Document Title	Status
SEC-DOC-005	Identity & Access Management (IAM)	**Published v1.0**
SEC-DOC-006	Data Flow Diagram & Traffic Matrix	Pending — requires screenshots
SEC-DOC-007	Disaster Recovery & Backup Plan	**Published v1.0**
SEC-DOC-008	Security Controls & Hardening Checklist	**Published v2.0**